

Security Principles

AGENDA

- i. Current treat landscape
- ii. Security fundamentals

WHERE WE ARE?

2026 Data Breach Investigations Report



<https://www.verizon.com/business/resources/reports/dbir/>

WHERE WE ARE?



The Data Breach Investigations Report (DBIR) focuses on the analysis of anonymized cybersecurity incident data that Verizon collects every year from almost a hundred data contributors. Those data points are normalized using the Vocabulary for Event Recording and Incident Sharing (VERIS) framework (more about it on the right), which provides us a great foundation for statistical analysis of this type of data.

Given the culture of secrecy (and just how difficult incident response is sometimes) that still permeates these cases, we often don't have all the very specific details of any given incident.

WHERE WE ARE?



Threat actor: Who is behind the event? This could be the external “bad guy” who launches a phishing campaign or an employee who leaves sensitive documents in their seat back pocket.

Threat action: What tactics (actions) were used to affect an asset? VERIS uses seven primary categories of threat actions: Malware, Hacking, Social, Misuse, Physical, Error and Environmental. Examples at a high level are hacking a server, installing malware or influencing human behavior through a social attack.

Incident vs. breach We talk a lot about incidents and breaches and we use the following definitions:

Incident: A security event that compromises the integrity, confidentiality or availability of an information asset.

Breach: An incident that results in the confirmed disclosure—not just potential exposure—of data to an unauthorized party. A distributed DoS (DDoS) attack, for instance, is most often an incident rather than a breach since data is rarely exfiltrated. However, we realize that doesn’t make it any less serious.

WHERE WE ARE?

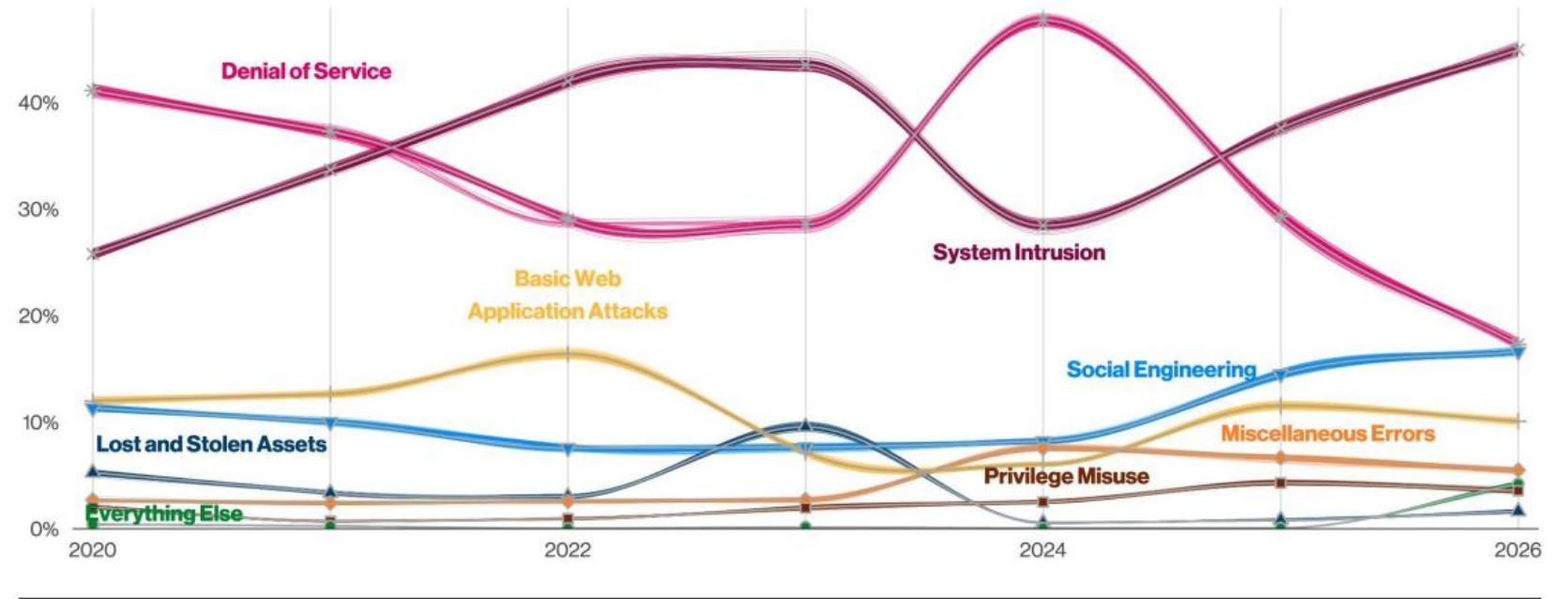


Figure 41. Patterns over time in incidents (n for 2026 dataset=31,860)

WHERE WE ARE?

System Intrusion

Summary

Threat actors are leveraging trusted applications, such as Remote Monitoring and Management (RMM) software, stolen credentials and exploits to monetize their access via Ransomware.

What is the same?

Ransomware continues to be the driving force behind the growth of System Intrusion.

Frequency	14,309 incidents, 13,758 with confirmed data disclosure
Threat actors	External (100%) (breaches)
Actor motives	Financial (88%), Espionage (12%) (breaches)
Data compromised	Internal (93%), Credentials (26%), Other (20%), Secrets (13%) (breaches)

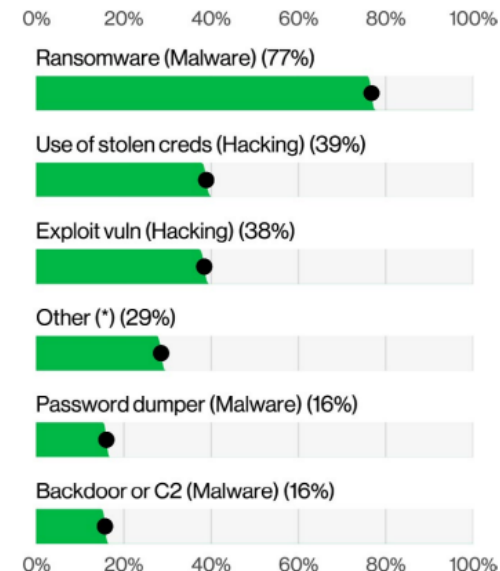


Figure 42. Top Action varieties in System Intrusion breaches (n=12,006)

WHERE WE ARE?

Social Engineering

Summary

Threat actors continue to largely leverage email-based phishing attacks to compromise organizations; however, these attacks are getting more complex as attackers are targeting mobile devices and other unconventional vectors to reach victims.

What is the same?

Email is still the preferred attack vector for the majority of Social Engineering breaches.

Frequency	5,302 incidents, 3,814 with confirmed data disclosure
------------------	---

Threat actors	External (100%) (breaches)
----------------------	----------------------------

Actor motives	Financial (86%), Espionage (25%) (breaches)
----------------------	---

Data compromised	Other (56%), Internal (51%), Credentials (39%), Secrets (31%) (breaches)
-------------------------	--

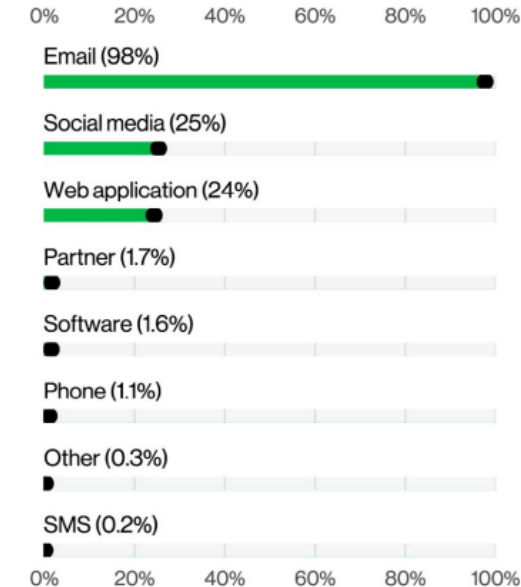


Figure 51. Top Social vectors in Social Engineering breaches (n=3,777)

Basic Web Application Attacks

Summary

Basic Web Application Attacks remain widespread and are typically driven by stolen credentials and unpatched vulnerabilities. While often low in sophistication, they are highly effective and frequently lead to credential theft, internal data exposure and further compromise of systems.

What is the same?

The Use of stolen creds continues its historic run in this pattern, showing the more things change, the more they remain the same.

Frequency

3,217 incidents, 2,281 with confirmed data disclosure

Threat actors

External (100%) (breaches)

Actor motives

Financial (74%), Espionage (23%), Ideology (3%) (breaches)

Data compromised

Credentials (52%), Internal (48%), Other (33%), Secrets (15%) (breaches)

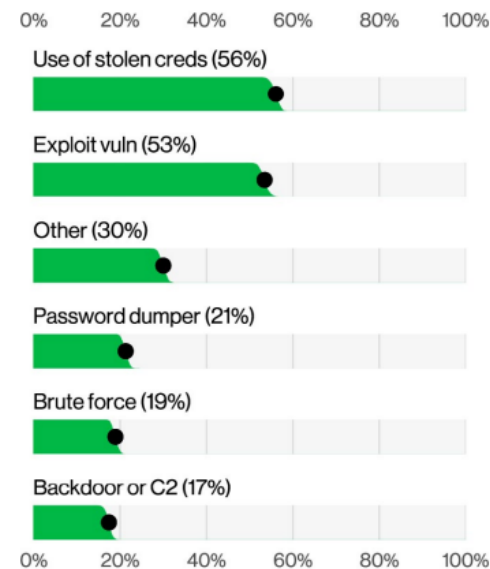


Figure 59. Top Action varieties in Basic Web Application Attacks breaches (n=2,193)

Miscellaneous Errors

Summary

Employee mistakes – especially Misdelivery and Misconfiguration – remain a persistent and significant cause of data breaches, often exposing personal data. Better access controls, monitoring and safeguards against common human errors are critical to reducing these incidents.

What is the same?

Errors were the cause of breaches slightly more often than last year. Misconfiguration and Misdelivery continue to be the primary issues organizations are experiencing in terms of the kinds of errors their employees are making.

Frequency

1,757 incidents, 1,750 with confirmed data disclosure

Threat actors

Internal (100%) (breaches)

Data compromised

Personal (98%), Internal (16%), Other (8%), Bank (7%) (breaches)

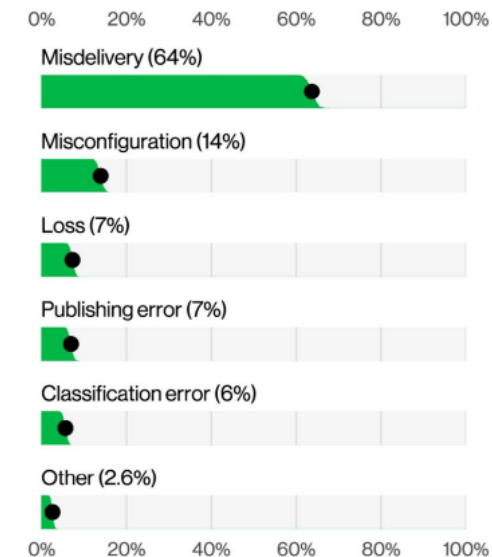


Figure 60. Top Action varieties in Miscellaneous Errors breaches (n=1,719)

WHERE WE ARE?

Privilege Misuse

Summary

Intentional insider misuse is less common than External attacks, but privileged access, convenience-driven policy violations, AI data leakage and fraudulent employee activities are growing insider-related risks that organizations must monitor closely.

What is the same?

Financially motivated insiders continue to steal data to benefit them down the road. Whether it is taking it to another employer or starting a competing business, these are notoriously difficult to detect.

Frequency	1,141 incidents, 766 with confirmed data disclosure
Threat actors	Internal (100%), External (1%), Multiple (1%) (breaches)
Actor motives	Convenience (60%), Financial (33%), Espionage (4%), Grudge (4%), Fun (2%), Other (2%) (breaches)
Data compromised	Personal (60%), Other (35%), Secrets (27%), Internal (25%) (breaches)

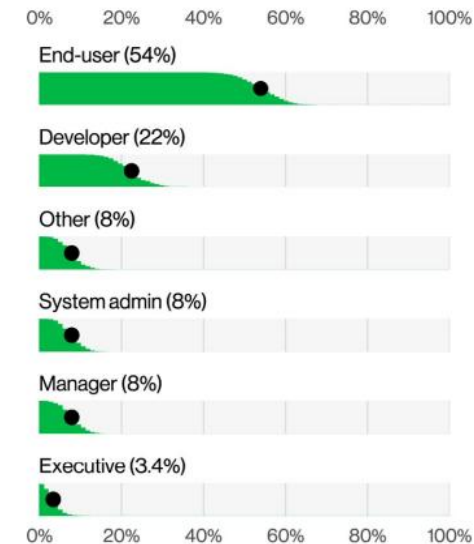


Figure 63. Top Actor varieties in Privilege Misuse breaches (n=89)

WHERE WE ARE?

Denial of Service

Summary

DDoS extremes continue to increase as organizations face erratic burst attacks year-round, with the median breached entity contending with 17 distinct attacks throughout the year.

Frequency

5,514 incidents, 3 with confirmed data disclosure

Threat actors

Internal (100%) (breaches)

What is the same?

DDoS attacks continue to be one of the top incidents targeting a wide variety of different industries.

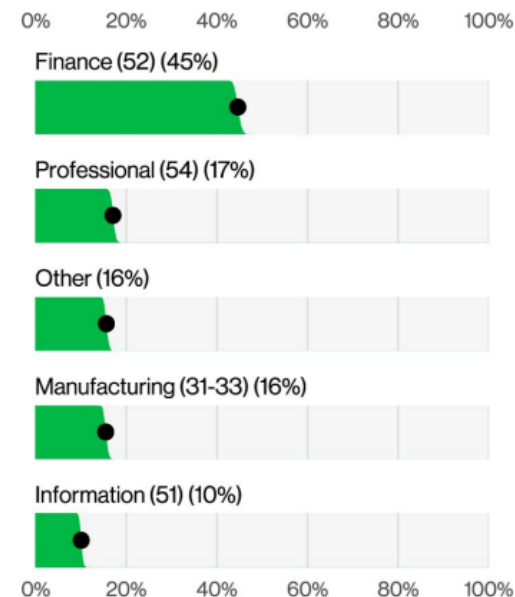


Figure 66. Top victim industries in DDoS incidents (n=5,513)

WHAT DOES THE FUTURE LOOK LIKE?

I. SECURITY FUNDAMENTALS

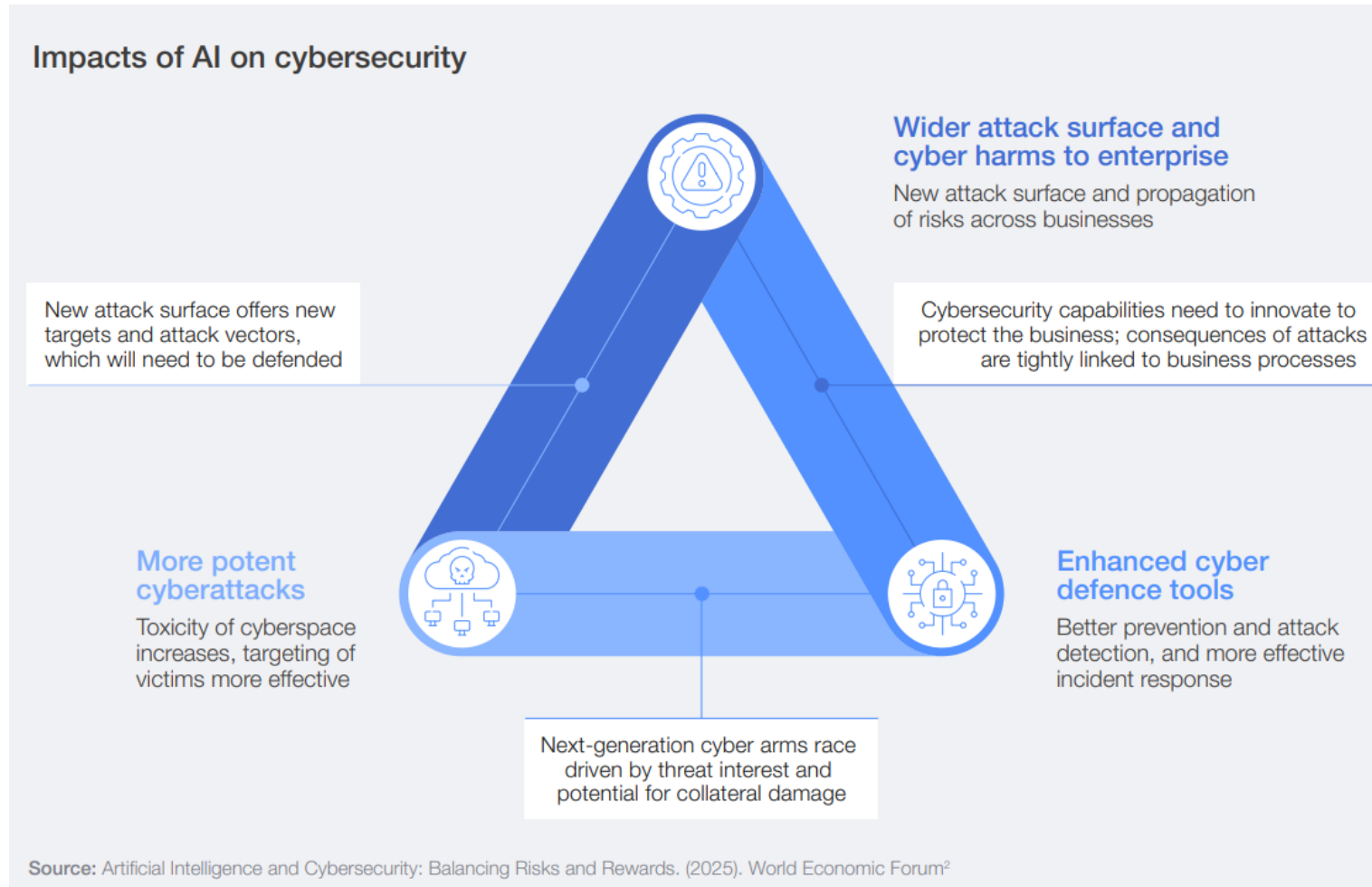


I. SECURITY FUNDAMENTALS

3 The trends reshaping cybersecurity

- 3.1 AI is reshaping risk, accelerating both offence and defence
- 3.2 Geopolitics is a defining feature of cybersecurity
- 3.3 The evolving landscape of cybercrime:
AI, fraud and the global response
- 3.4 Cyber resilience is the key to safeguarding economic value
- 3.5 Securing supply chains amid opacity and concentration risks
- 3.6 Drivers of cyber inequity in 2026
- 3.7 Future threat vectors are emerging in silence

3.1. AI is reshaping risk, accelerating both offence and defence

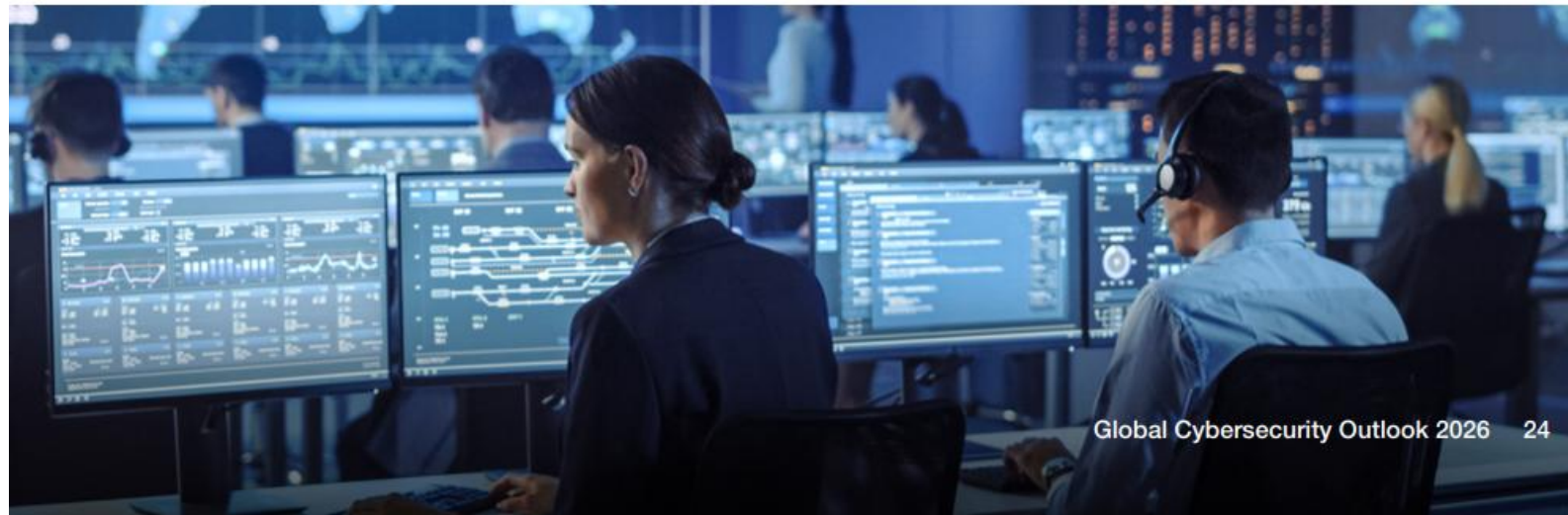


3.2 Geopolitics is a defining feature of cybersecurity

In an increasingly fragmented global environment – marked by conflicts, geoeconomic tensions, trade wars, sanctions and growing technological competition – geopolitics has become a defining force shaping cybersecurity.

The *Global Cybersecurity Outlook 2026* survey data reveals that, although the percentage of organizations

changing their cybersecurity strategy due to geopolitics has declined from 93% in 2023 to 66% in 2026, geopolitics remains the top factor influencing overall cyber risk mitigation strategies. This suggests that the initial wave of adaptations following the geopolitical turmoil that dominated the headlines in 2022 and 2023 has passed, and that geopolitical risk is now a major factor shaping cyber defence.



3.3 The evolving landscape of cybercrime: AI, fraud and the global response

Over the course of 2025, several high-profile cybercrime cases have dominated the headlines, with cyberattacks disrupting retail, businesses and manufacturing operations – and even targeting nurseries.¹⁶

Ransomware continues to be the leading concern for CISOs; by contrast, CEOs tend to be more concerned on the broader business impacts of frauds. For CISOs this concern reflects the significant operational disruption a successful ransomware attack can inflict on the availability of critical information technology (IT) and operational technology (OT) systems. Many of the major cyber incidents that made the headlines in 2025 were, in fact, driven by ransomware demands. As one

of the most lucrative tactics for cybercriminals, ransomware remains a persistent threat, and the increasing integration of AI into attack methods is expected to make these attacks even more effective.

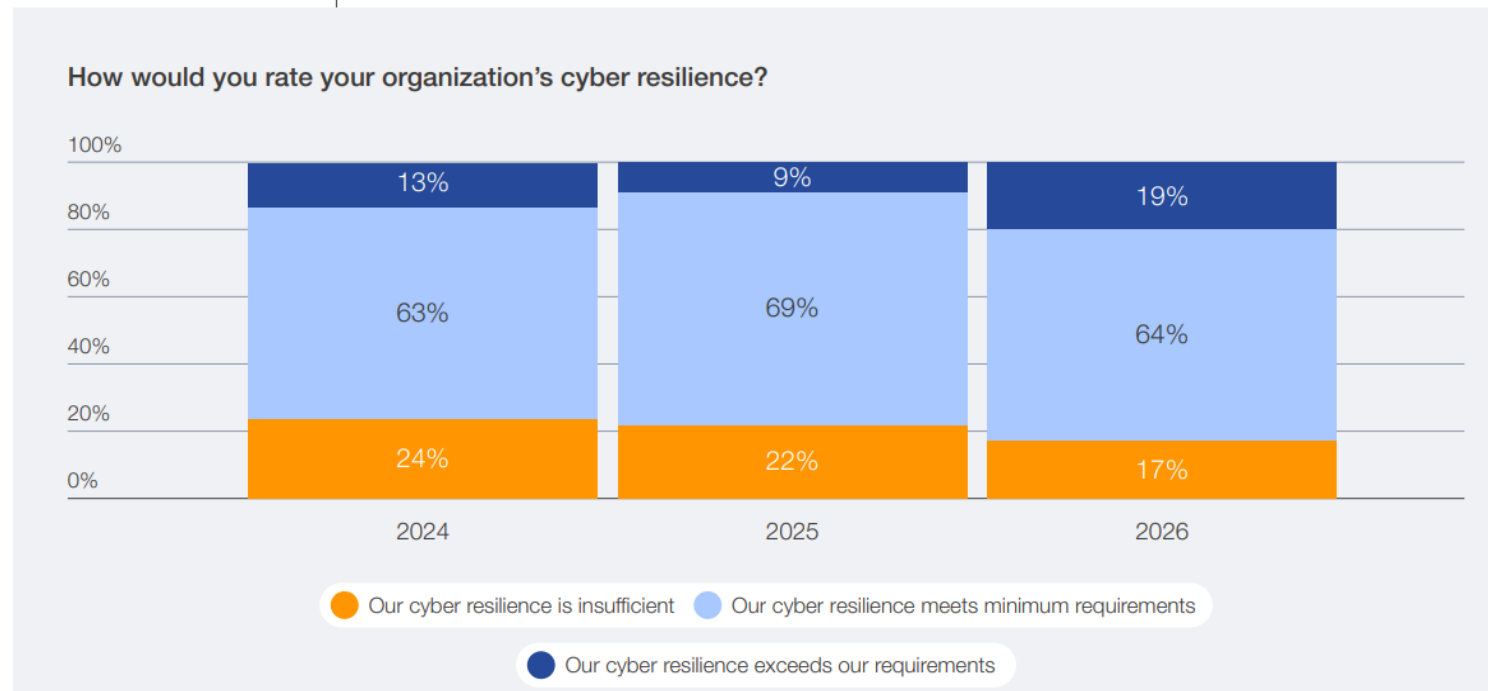
Cyber-enabled fraud continues to grow in scale, taking a heavy toll on individuals and organizations around the world. According to the *Global Cybersecurity Outlook* survey data, 77% of respondents reported an increase in cyber-enabled fraud and phishing overall, while 73% claimed that they or someone in their network had been personally affected by cyber-enabled fraud. The three most common types of attacks reported are phishing (including vishing and smishing), payment fraud and identity theft.

3.4 Cyber resilience is the key to safeguarding economic value

Cyber resilience underpins an organization's ability to minimize the impact of significant cyber incidents on its primary business goals and objectives.³⁰ Survey data shows increasing confidence in organizational cyber resilience. While 64% of organization report having met their minimum cyber

resilience requirements, regardless of regional or sectorial variation (as further detailed in Section 3.6), only 19% claimed that cyber resilience exceeds their requirements. This is, however, a double-digit increase compared to 2025, when only 9% reported exceeding resilience requirements.

FIGURE 24 Year-over-year perception of cyber resilience



3.5 Securing supply chains amid opacity and concentration risks

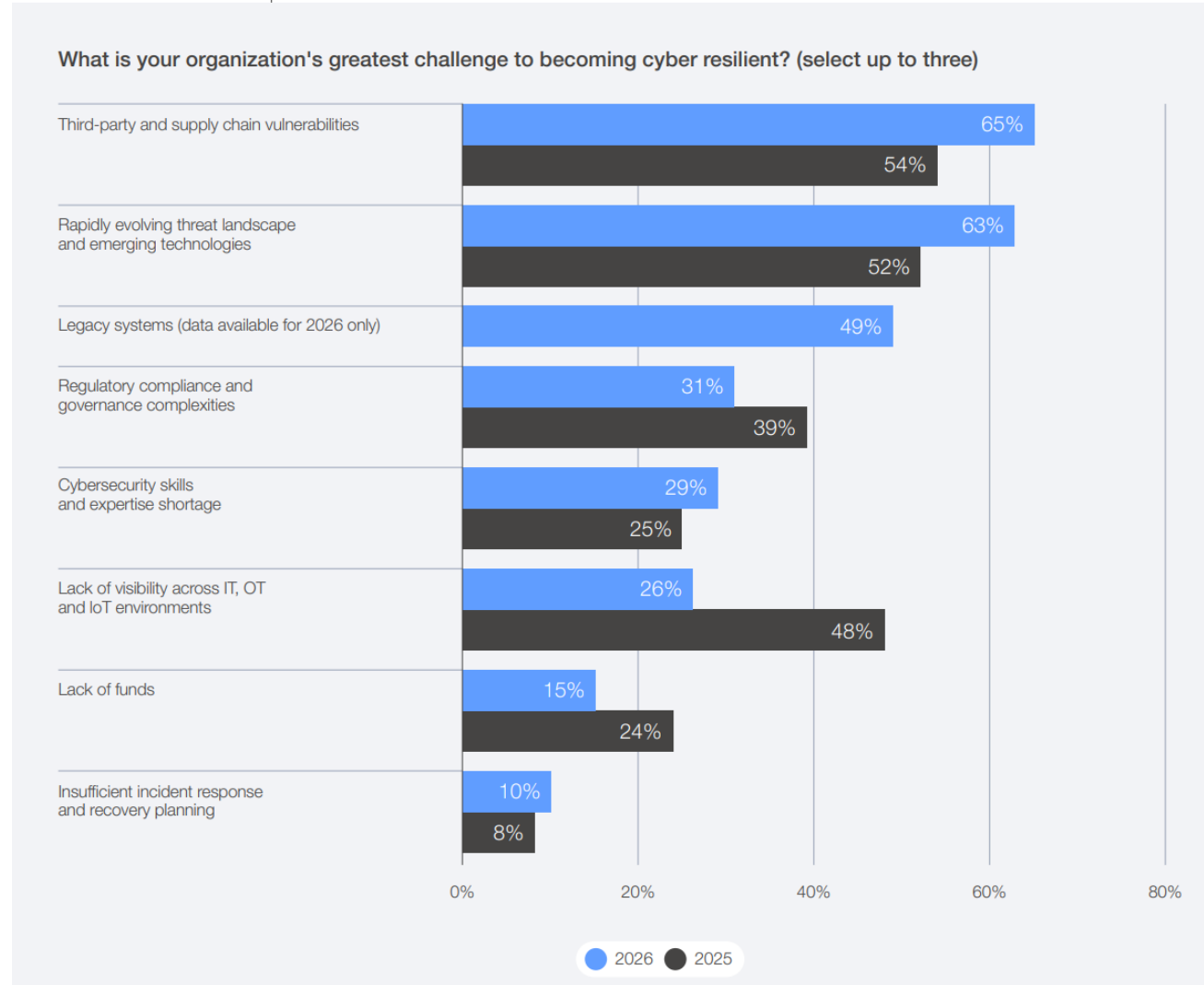
The digital supply chain is highly interconnected, with dependencies within and across industries that are often not clearly mapped. A breach or disruption of one supplier can cascade through the entire ecosystem, affecting production, operations and even other suppliers or customers. This complexity makes it difficult to assess and manage cyber risk effectively. Attacks on widely used software or service providers can have global and systemic impacts.

Such critical interdependencies were highlighted by the cyberattack affecting airports across Europe in September 2025, where a relatively minor breach targeting the check-in and boarding systems used by several major airport hubs caused a cascading

disruption to airport operations, with flight delays and cancellations.⁴¹ Though the immediate damage was contained, the incident exposed the fragility of interconnected digital supply chains, leaving participants in focus groups for this report to reflect on how devastating a similar attack could be if directed at hospitals or other critical infrastructure.

Concerns about the resilience of supply chains against cyberattacks are continuing to worry business and cyber executives. This year's survey data shows that 65% of large companies by revenue indicate third-party and supply chain vulnerabilities are their greatest challenge, which has risen from 54% in 2025.⁴²

FIGURE 37 | Large companies' greatest barriers to cyber resilience, 2025–2026

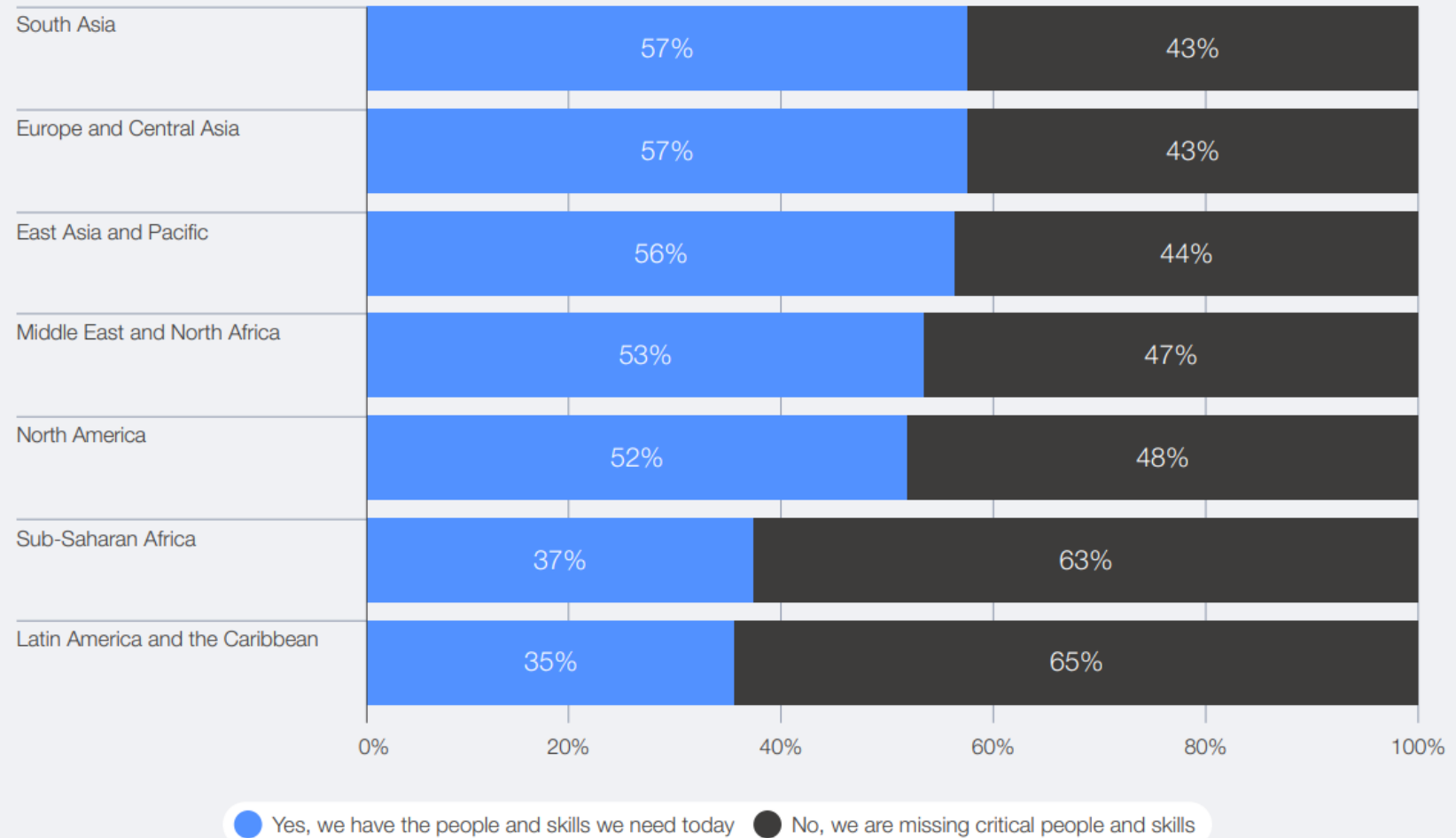


3.6 Drivers of cyber inequity in 2026

Cyber capacity across the global ecosystem remains uneven across industries and regions, influenced by differences in skills, resources and available digital infrastructure and governance frameworks. While certain organizations continue to invest in security, many others face challenges in sustaining even a baseline level of cybersecurity. This imbalance – described as cyber inequity – creates vulnerabilities that extend beyond individual entities, exposing entire interconnected supply chains to risk. The *Global Cybersecurity Outlook 2025* examined this inequity through three key dimensions: small versus large organizations; developed versus emerging economies; and disparities across sectors.

The 2026 survey data reveals that perceptions of resilience levels still vary across regions. High degrees of confidence in resilience levels are expressed by respondents based in the Middle East and North Africa, while lower levels of resilience are expressed in Latin America and the Caribbean and sub-Saharan Africa. Despite rising confidence in cyber resilience overall, inequities persist between smaller and larger organizations.⁴⁷ Survey data indicates that small organizations (by revenue) are twice as likely to experience insufficient resilience levels as large organizations. Similarly, across sectors, survey data reveals that the divide remains: NGOs report 37% insufficient resilience, and the public sector 23%, compared with just 11% in the private sector.

Does your organization's workforce have the skills needed to achieve its current cybersecurity objectives?



3.7 | Future threat vectors are emerging in silence

While AI continues to dominate the cybersecurity landscape, several other technologies and threat vectors are quietly gaining traction in the background and are expected to affect cybersecurity by 2030.

Drawing on a focus group session with members of the Global Future Councils – including Artificial

General Intelligence, Clean Air, Cybersecurity, Data Frontiers, Decentralized Finance, Energy Technology Frontiers, Generative Biology, Geopolitics, Information Integrity, and Next-Generation Computing – it is possible to integrate their forward-looking perspectives with data from the *Global Cybersecurity Outlook 2026* survey to reveal the emerging risks likely to define cybersecurity in the coming years.

Autonomous systems
and robotics

Digital currencies

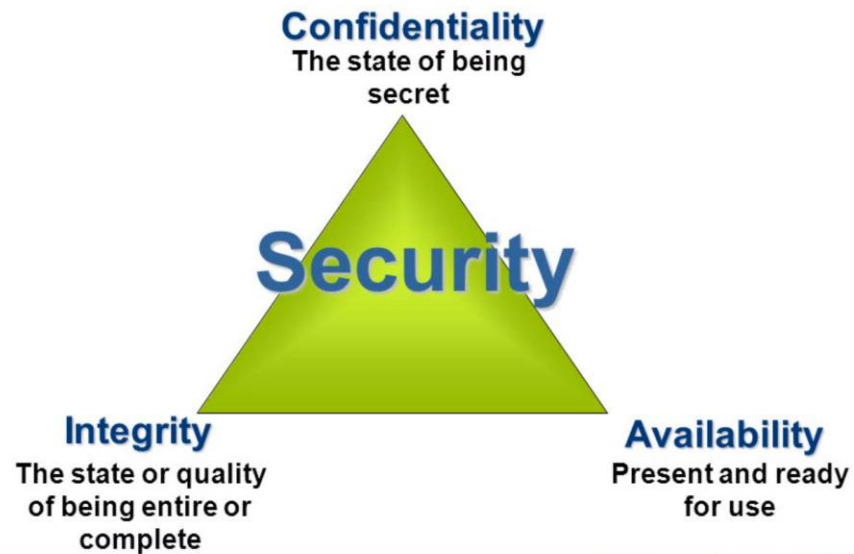
Space technologies
and undersea cables

SECURITY FUNDAMENTALS

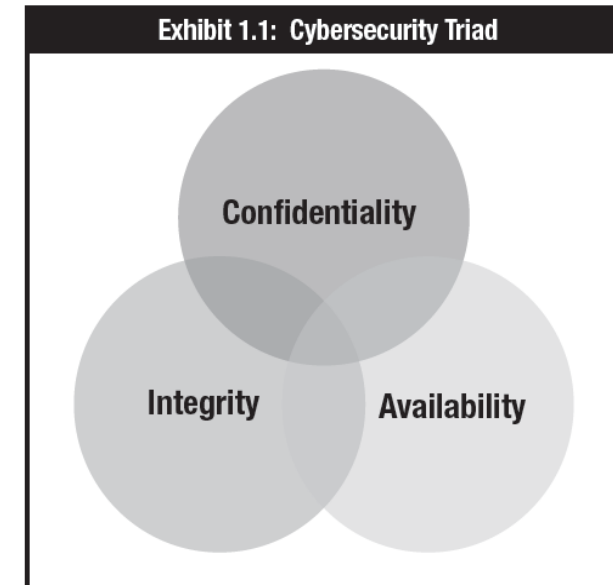
I. INTRODUCTION TO CYBERSECURITY

Three key concepts:

- Confidentiality: Protection from unauthorized **access**
- Integrity: Protection from unauthorized **modification**
- Availability: Protection from **disruptions** in Access. Reliable access to information and systems



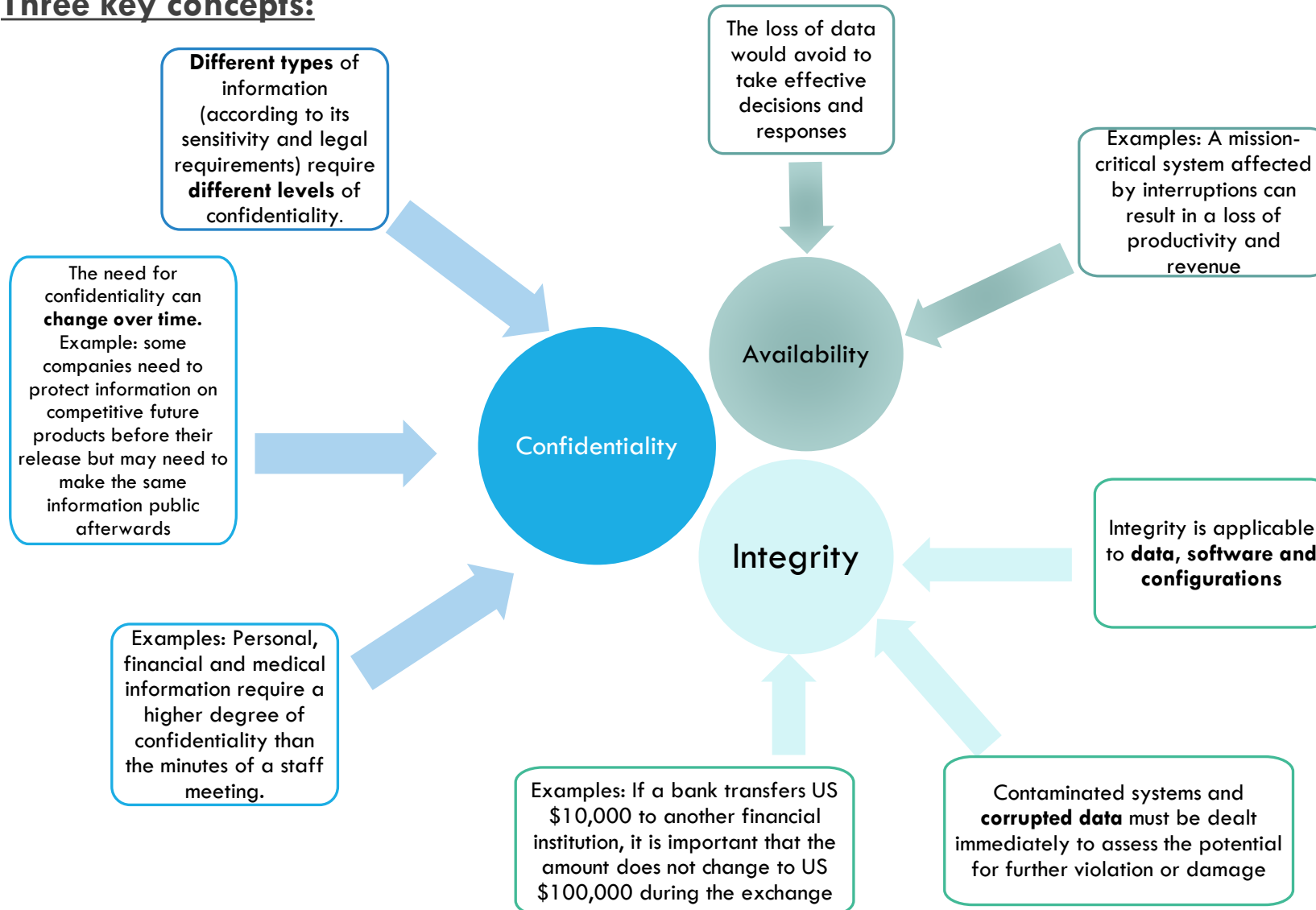
Source: <http://slideplayer.com/slide/8573727/>



Source: CSX Cybersecurity Fundamentals, Study Guide, 2nd Edition

I. INTRODUCTION TO CYBERSECURITY

Three key concepts:



I. INTRODUCTION TO CYBERSECURITY

Three key concepts:

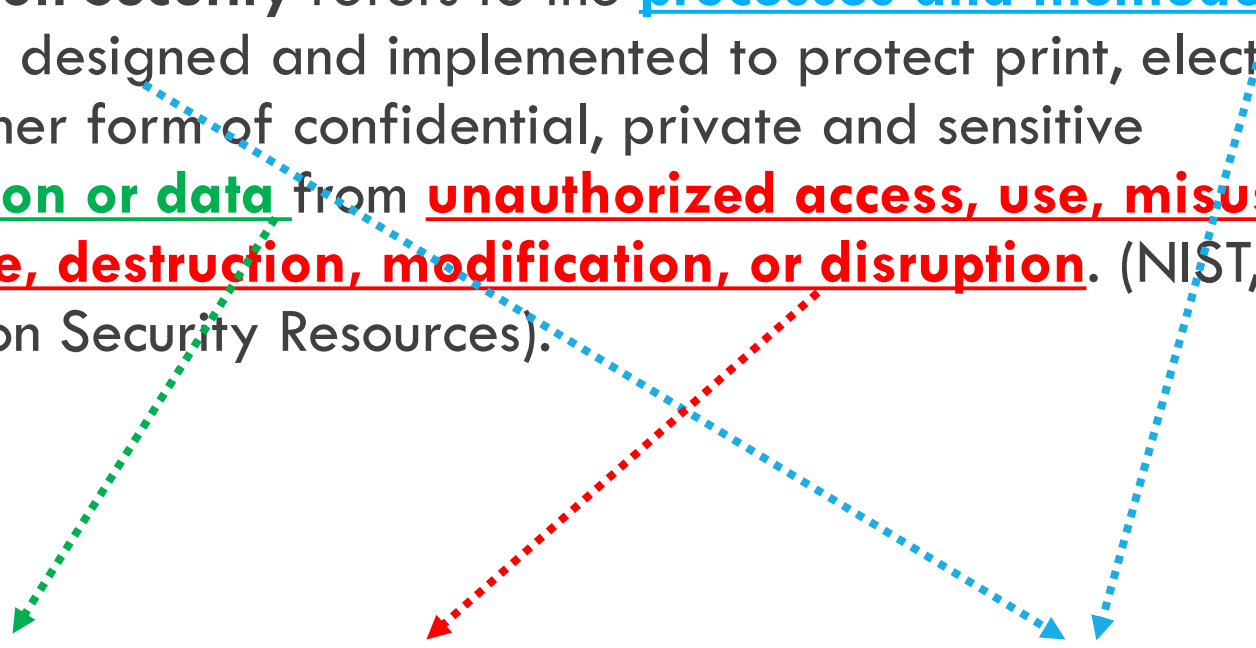
Identify a physical and digital data and indicate how are its requirements in terms of CID and how it is being protected (e.g. **Physical** Medical Prescription, **Digital** Grade Report).

Data/Asset #1	Requirements for each key concept (CID)	Explain how the asset is being protected in each key concept (CID)
Confidentiality (C)	...	...
Integrity (I)	...	...
Availability (D)	...	...

I. INTRODUCTION TO CYBERSECURITY

Definiton of Information Security:

Information Security refers to the processes and methodologies which are designed and implemented to protect print, electronic, or any other form of confidential, private and sensitive information or data from unauthorized access, use, misuse, disclosure, destruction, modification, or disruption. (NIST, Information Security Resources).



Data/Asset #1	Requirements for each key concept (CID)	Explain how the asset is being protected in each key concept (CID)
Confidentiality (C)	...	...
Integrity (I)	...	...
Availability (D)	...	...

I. INTRODUCTION TO CYBERSECURITY

Primer postulado
en seguridad de la
información:

La Seguridad es tan fuerte como el más débil de los mecanismos de apoyo que tenga implementado; así como una cadena es tan fuerte como el más débil de sus eslabones

*"Las organizaciones gastan millones de dólares en firewalls y dispositivos de seguridad, pero tiran el dinero porque ninguna de estas medidas cubre el eslabón más débil de la cadena de seguridad: **la gente que usa y administra los ordenadores**".*

Kevin Mitnick



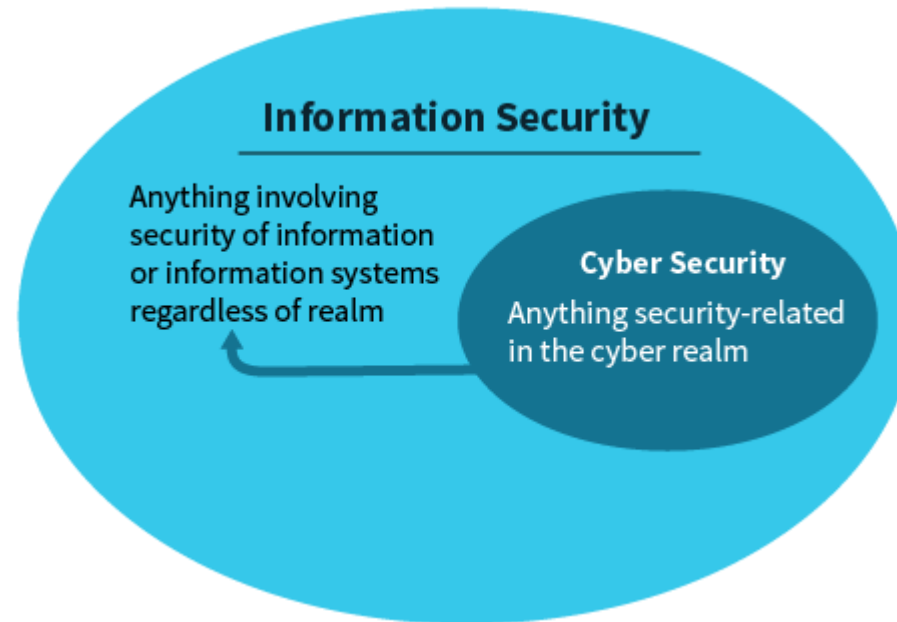
I. INTRODUCTION TO CYBERSECURITY

Definition of Cybersecurity:

Cybersecurity: Protection of **information assets** by addressing threats to **digital information** processed, stored and transported by **internetworked** information systems.

Realms:

- Physical security
- Natural hazards
- Personal mistakes
- Cyber Realm



Cyber Realm:

- Intentional attacks
- Breaches
- Incidents
- Impacts
- Offensive
- Adversary human behavior

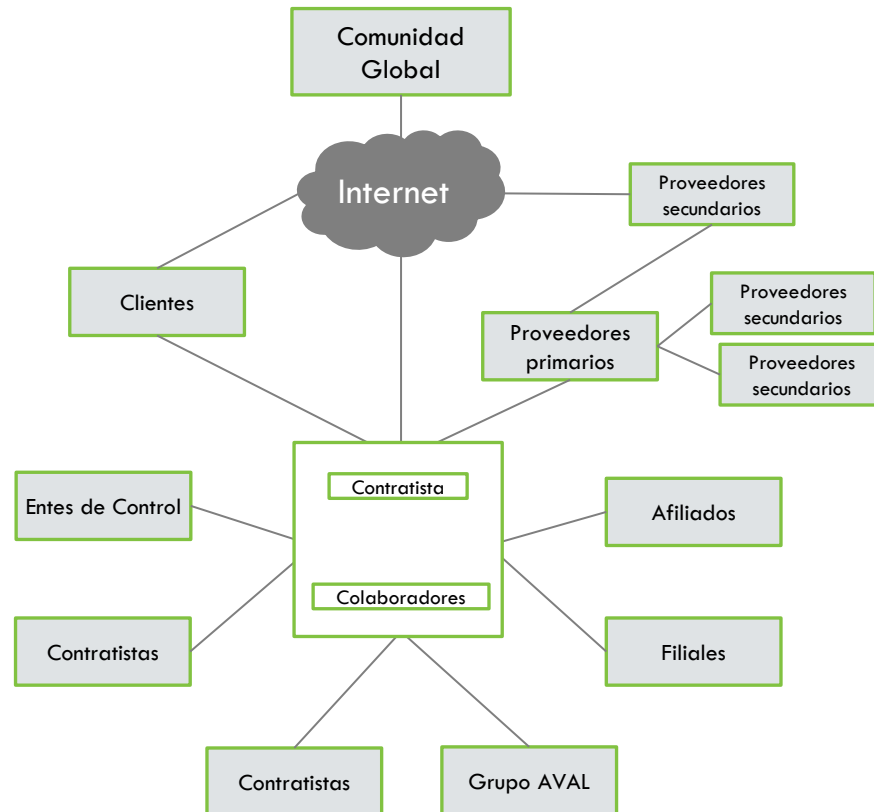
Source:
Data protection vs. information security vs. cyber security. (n.d.). Retrieved October 14, 2017, from <https://www.legalfutures.co.uk/associate-news/data-protection-vs-information-security-vs-cyber-security>

Cybersecurity is **included** in
information security

Cybersecurity **does not** include natural hazards,
personal mistakes or physical security

I. INTRODUCTION TO CYBERSECURITY

Definition of Cybersecurity:



Ciberspacio: Entorno complejo resultante de la interacción de personas, software y servicios en Internet a través de dispositivos tecnológicos conectados a dicha red, el cual no existe en ninguna forma física.¹

Seguridad de la Información: Es el conjunto de políticas, estrategias, metodologías, recursos, soluciones informáticas, prácticas y competencias para proteger, asegurar y preservar la confidencialidad, integridad y disponibilidad de la información de la entidad.¹

Ciberseguridad: Es el desarrollo de capacidades empresariales para defender y anticipar las amenazas cibernéticas con el fin de proteger y asegurar los datos, sistemas y aplicaciones en el ciberespacio que son esenciales para la operación de la entidad.¹

I. INTRODUCTION TO CYBERSECURITY

Cybersecurity professionals have three primary objectives when it comes to protecting information and systems. They want to ensure that private data remains secret (confidentiality), that information isn't altered without permission (integrity), and that information is available to authorized users when they need it (availability). You can remember these three main goals by thinking of the CIA triad, as shown in Figure 1.1. Each side of this triangle covers one of the three main goals.

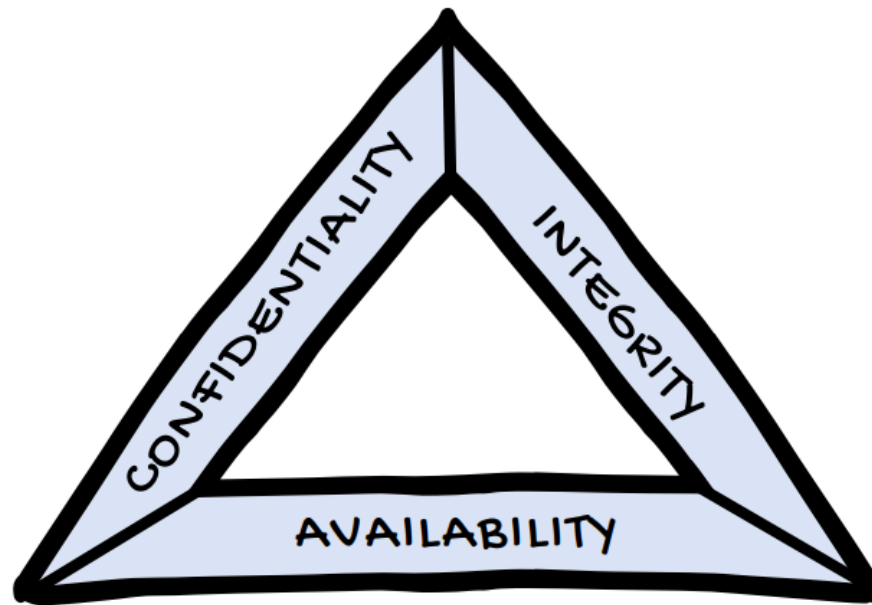


FIGURE 1.1 The CIA triad summarizes the three main goals of information security: confidentiality, integrity, and availability.

INTEGRITY RISKS

Unauthorized Modification of Information The unauthorized modification of information occurs when an attacker gains access to a system and makes changes that violate a security policy. This might be an external attack, such as an intruder breaking into a financial system and issuing themselves checks, or it might be an internal attack, such as an employee increasing their own salary in the payroll system.

Following the principle of *least privilege* is the best way to protect against integrity attacks. Organizations should carefully consider the permissions that each employee needs to perform their job and then limit employees to the smallest set of permissions possible.

Man-in-the-Middle Attacks Sometimes impersonation attacks are electronic. In a *man-in-the-middle (MitM) attack*, the attacker intercepts network traffic as a user is logging into a system and pretends to be that system. They then sit in the middle of the communication, relaying information between the user and the system while they monitor everything that is occurring. In this type of attack, the attacker might be able to steal a user's password and use it later to log in to the system themselves.

Impersonation In an *impersonation* attack, the attacker pretends to be someone other than who they actually are. They might impersonate a manager, executive, or IT technician in order to convince someone to change data in a system. This is an extension of the social engineering attacks mentioned earlier, and the best defense against these attacks is strong user education.

Replay Attacks In a *replay attack*, the attacker doesn't get in the middle of the communication but finds a way to observe a legitimate user logging into a system. They then capture the information used to log in to the system and later replay it on the network to gain access themselves.

AVAILABILITY RISKS

Denial-of-Service Attacks *Denial-of-service (DoS) attacks* occur when a malicious individual bombards a system with an overwhelming amount of network traffic. The idea is to simply send so many requests to a server that it is unable to answer any requests from legitimate users.

You can protect your systems against DoS attacks by using firewalls that block illegitimate requests and by partnering with your Internet service provider to block DoS attacks before they reach your network.

Hardware Failures Hardware failures can and do occur. Servers, hard drives, network gear, and other equipment all fail occasionally and can disrupt access to information. That's an availability problem.

You can protect against hardware failures by building a system that has built-in redundancy so that if one component fails, another is ready to pick up the slack.

Service Outages Finally, sometimes service outages occur. This might be due to programming errors, the failure of underlying equipment, or many other reasons. These outages disrupt user access to systems and information and are, therefore, an availability concern.

You can protect against service outages by building systems that are resilient in the face of errors and hardware failures.

Power Outages Power outages can occur on a local or regional level for many different reasons. Increased demand can overwhelm the power grid; natural disasters can disrupt service; and other factors can cause power outages that disrupt access to systems.

You can protect against power outages by having redundant power sources and backup generators that supply power to your system when commercial power is not available.

Destruction of Equipment Sometimes equipment is just outright destroyed. This might be the result of intentional or accidental physical damage, or it may be the result of a larger disaster, such as a fire or a hurricane.

You can protect against small-scale destruction with redundant systems. If you want to protect against larger-scale disasters, you may need to have backup data centers in remote locations or in the cloud that can keep running when your primary data center is disrupted.

I. INTRODUCTION TO CYBERSECURITY

NON-REPUDIATION

Another important focus of some security controls is providing *non-repudiation*. Repudiation is a term that means denying that something is true. Non-repudiation is a security goal that prevents someone from falsely denying that something is true.

For example, you might agree to pay someone \$10,000 in exchange for a car. If you just had a handshake agreement, it might be possible for you to later repudiate your actions. You might claim that you never agreed to purchase the car or that you agreed to pay a lower price.

To solve this issue, a signed contract is used when a car is sold. Your signature on the document is the proof that you agreed to the terms, and if you later go to court, the person selling you the car can prove that you agreed by showing the judge the signed document. Physical signatures provide non-repudiation on contracts, receipts, and other paper documents.

I. INTRODUCTION TO CYBERSECURITY

EXAM ESSENTIALS

- ▶ The CIA triad references the three main goals of information security: confidentiality, integrity, and availability.
- ▶ Confidentiality protects sensitive information from unauthorized access. The major threats to confidentiality include snooping, dumpster diving, eavesdropping, wiretapping, and social engineering.
- ▶ Integrity protects information and systems from unauthorized modification. The major threats to integrity include the unauthorized modification of information, impersonation attacks, man-in-the-middle attacks, and replay attacks.
- ▶ Availability ensures that authorized users have access to information when they need it. The major threats to availability include denial-of-service attacks, power outages, hardware failures, destruction of equipment, and service outages.
- ▶ Non-repudiation uses technical measures to ensure that a user is not able to later deny that they took some action.

AUTHENTICATION AND AUTHORIZATION

AUTHENTICATION AND AUTHORIZATION

Access control defined

Access control is an essential element of security that determines who is allowed to access certain data, apps, and resources—and in what circumstances. In the same way that keys and preapproved guest lists protect physical spaces, access control policies protect digital spaces. In other words, they let the right people in and keep the wrong people out. Access control policies rely heavily on techniques like [authentication](#) and authorization, which allow organizations to explicitly verify both that users are who they say they are and that these users are granted the appropriate level of access based on context such as device, location, role, and much more.

Access control keeps confidential information—such as customer data and intellectual property—from being stolen by bad actors or other unauthorized users. It also reduces the risk of data exfiltration by employees and keeps web-based threats at bay. Rather than manage permissions manually, most security-driven organizations lean on identity and access management solutions to implement access control policies.

Identification

During the first step of the process, *identification*, an individual makes a claim about their identity. The person trying to gain access doesn't present any proof at this point; they simply make an assertion. It's important to remember that the identification step is only a claim, and the user could certainly be making a false claim! Imagine a physical-world scenario in which you want to enter a secure office building where you have an appointment. During the identification step of the process, you might walk up to the security desk and say, "Hi, I'm Mike Chapple."

Authentication

Proof comes into play during the second step of the process: *authentication*. During the authentication step, the individual proves their identity to the satisfaction of the access control system. In the office building example, the guard would likely want to see my driver's license to confirm my identity.

Authorization

Just proving your identity isn't enough to gain access to a system, however. The access control system also needs to be satisfied that you are *allowed* to access the system. That's the third step of the access control process: *authorization*. In the office building example, the security guard might check a list of that day's appointments to see if it includes my name.

Accounting

In addition to identification, authentication, and authorization, access control systems also provide an *accounting* functionality that allows administrators to track user activity and reconstruct it from logs. In the case of the office building example, the security guard may write down my access to the building in a visitor logbook. Figure 2.1 shows this process all coming together.

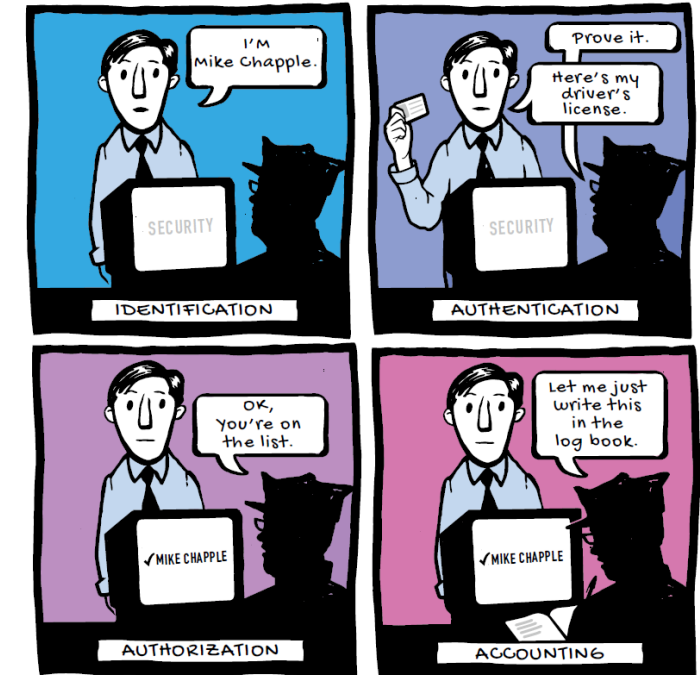


FIGURE 2.1 The physical access control process

DIGITAL ACCESS CONTROL

So far, I've talked about identification, authentication, authorization, and accounting in the context of gaining access to a building. Now I'll discuss how they work in the electronic world. When we log in to a system, we most often identify ourselves using a username, most likely composed of some combination of the letters from our names. When we reach the authentication phase, we're commonly asked to enter a password.



PASSWORD POLICIES

When you set a password policy for your organization, you have a number of technical controls available that allow you to set requirements for how users choose and maintain their passwords. This section discusses a few of those mechanisms.



FIGURE 2.2 The digital access control process

PASSWORD POLICIES

Password Length

The simplest and most common control on passwords is setting the *password length*. This is simply the minimum number of characters that must be included in a password. It's good practice to require that passwords be at least eight characters, but some organizations require even longer passwords. The longer a password is, the harder it is to guess.

Password Complexity

Organizations may also set *password complexity* requirements. These requirements force users to include different types of characters in their passwords, such as uppercase and lowercase letters, digits, and special characters. Just as with password length, the more character types there are in a password, the harder it is to guess.

Password Expiration

Password expiration requirements force users to change their passwords periodically. For example, an organization might set a password expiration period of 180 days, forcing users to change their passwords every 6 months. These days, many organizations no longer have password expiration requirements, allowing users to keep the same password for as long as they'd like and only requiring that they change it if the password is compromised.

Password History

Password history requirements are designed to prevent users from reusing old passwords. Organizations with password history requirements configure their systems to remember the previous passwords used by each user and prevent them from reusing that password in the future. Password history controls allow the administrator to identify how many old passwords are remembered for each user.

Password Resets

Every organization should allow users to change their passwords quickly and easily. You want users to be able to privately select their own passwords and do so whenever they are concerned that their password may be compromised.

One point of caution is that organizations should carefully evaluate their password reset process for users who forget their passwords. If they're not designed well, these processes can provide an opportunity for attackers to gain access to a system by performing an unauthorized password reset.

Password Reuse

IT teams should also strongly encourage users not to reuse the same password across multiple sites. This is difficult to actually enforce, but it does provide a strong measure of security. If a user reuses the same password on many different sites and one of those sites is compromised, an attacker might test that password on other sites, hoping that the password owner reuses the same password.

PASSWORD POLICIES

Password Managers

It's difficult for users to manage unique passwords for every site they visit. That's where password managers play a crucial role. These valuable tools are secure password vaults, often protected by biometric security mechanisms that create and store unique passwords. They then automatically fill those passwords on websites when the user visits them. That way users can have unique, strong passwords for every site they visit without having to remember them all.

Figure 2.3 shows an example of LastPass, a popular password manager, being used to create a new, strong password.

Chapter 2 • Authentication and Authorization

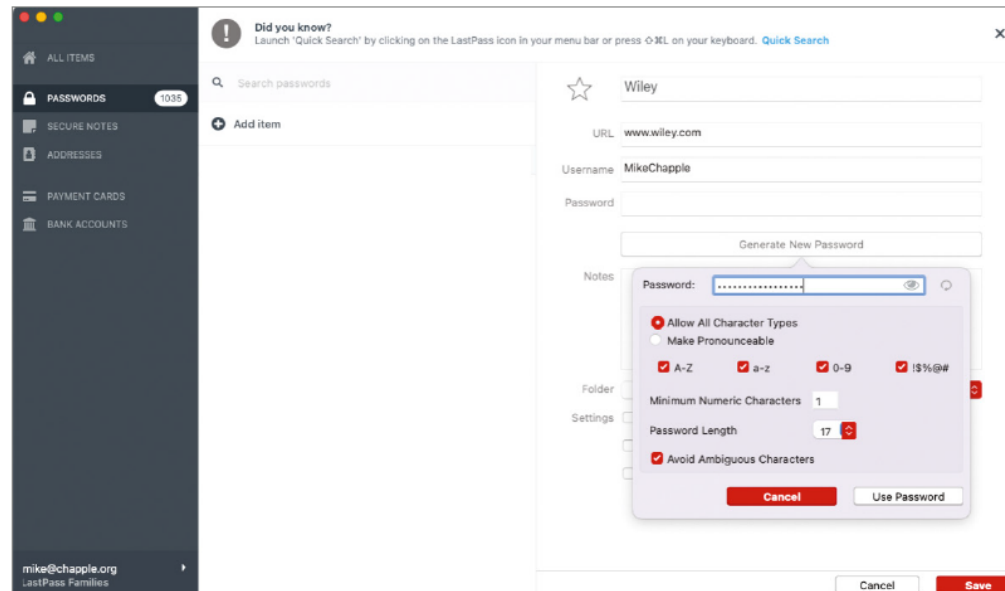


FIGURE 2.3 Creating a password in LastPass

AUTHENTICATION FACTORS

Computer systems offer many different authentication techniques that allow users to prove their identity. This section looks at the following three authentication factors:

- ▶ Something you know
- ▶ Something you are
- ▶ Something you have

AUTHENTICATION FACTORS

Something You Know

By far, the most common authentication factor is *something you know*. I've already talked about how passwords are the most commonly used authentication technique. This is a "something you know" factor because the password is something that the user remembers and enters into a system during the authentication process. Personal identification numbers (PINs) and the answers to security questions are also examples of something you know.

AUTHENTICATION FACTORS

Something You Are

The second authentication factor is *something you are*. *Biometric* authentication techniques measure one of your physical characteristics, such as a fingerprint, eye pattern, face, or voice. Figure 2.4 shows an example of a smartphone fingerprint reader performing biometric authentication.

Figure 2.5 shows a more complex eye scan being performed as a biometric access control for entering a facility.

AUTHENTICATION FACTORS

Something You Have

The third authentication factor, *something you have*, requires the user to have physical possession of a device, such as a smartphone running a software token application or a hardware authentication token key fob. These devices generate onetime passwords that are displayed to the user and allow them to prove that they have access to a physical device. Similarly, smart cards can serve as a “something you have” factor, requiring that the user insert a card with a digital chip into a specialized reader.

AUTHENTICATION FACTORS

Multi-factor Authentication

When used alone, any one of these techniques provides some security for systems. However, they each have their own drawbacks. For example, an attacker might steal a user's password through a phishing attack. Once they have the password, they can then use that password to assume the user's identity. Other authentication factors aren't foolproof either. If you use smart card authentication to implement something you have, the user may lose the smart card. Someone coming across it may then impersonate the user.

The solution to this problem is to combine authentication techniques from multiple factors, such as combining something you know with something you have. This approach is known as *multi-factor authentication (MFA)*.

AUTHENTICATION FACTORS

EXAM ESSENTIALS

- ▶ The access control process consists of three major steps. Identification is when a user makes a claim of identity. Authentication is when the user proves that identity claim. Authorization is when the system determines whether the user is allowed to perform a requested action.
- ▶ Accounting processes create a record of who performed which actions on a system and are useful when investigating security incidents.
- ▶ Multi-factor authentication combines at least two of the three factors: something you know, something you have, and something you are.
- ▶ Password length requirements set a minimum number of characters that must be in a user's password, whereas password complexity requirements mandate the use of different character types.
- ▶ Password history requirements prevent the reuse of old passwords, whereas password expiration requirements force the periodic reset of existing passwords. Users should be permitted to reset their passwords whenever they wish.
- ▶ Users should be encouraged not to reuse passwords across multiple sites, as this increases the risk of compromise. Password managers provide a convenient tool for managing many unique, strong passwords.

Gracias